

E5 no equivale a readiness:

la decisión correcta para habilitar Microsoft 365 Copilot

Microsoft 365 E5 entrega la plataforma de control. Microsoft 365 Copilot requiere licenciamiento adicional y una decisión basada en controles, evidencia y resultados medibles.

1. PLATAFORMA BASE: MICROSOFT 365 E5

Capacidades de control ya disponibles



2. COMPLEMENTO: MICROSOFT 365 COPILOT

Licenciamiento adicional



3. CONDICIONES DE ENTRADA: READINESS VERIFICABLE

Debe evaluarse y demostrarse



4. RESULTADO: DECISIÓN Y VALOR

Basado en evidencia y control



No requiere instalación

Copilot se habilita por licencia. No hay agentes ni despliegues de escritorio.



Construido sobre Microsoft 365

Requiere E3/E5, identidades de Microsoft Entra y Microsoft 365 Apps en canal de actualización soportado.



Seguro por diseño

Copilot solo muestra información que el usuario ya tiene permiso para ver y respeta las etiquetas de sensibilidad.



Foundations+ guide

Guía integrada en el centro de administración de Microsoft 365 para un despliegue guiado de extremo a extremo.



E5 ≠ Ready.

La preparación se demuestra con controles efectivos, evidencia y resultados.

LEYENDA

✓ Cumple

⚠ Brecha / Riesgo

NE No evaluado

P0 / P1 / P2 Prioridad



Estado actual del tenant:
No evaluado (NE)

Cadena de confianza de Microsoft 365 Copilot: de la identidad al valor

Microsoft Copilot opera dentro del límite de servicio de Microsoft 365. Cada componente aporta control, identidad y contexto. La confianza se construye cuando todos los eslabones funcionan e integran sus señales.

CONTROLES DE BORDE

- MFA y autenticación sin contraseña
- Conditional Access y Authentication Strength
- Cumplimiento de dispositivo
- Etiquetas de sensibilidad y DLP
- Permisos y acceso mínimo necesario
- Control de sesión y de datos
- Audit, retención y eDiscovery

FEEDBACK
CONFIANZA



SERIE DE 2 VOLUMENES

Volumen 1: Marco de licenciamiento y análisis comparativo por escenario (dimensión de decisión)



INTEGRACIÓN (SEÑALES Y ACCIONES)



DEPENDENCIAS CRÍTICAS



Las dependencias requieren pruebas end-to-end para ser operativas.

PRINCIPIO CENTRAL

Copilot solo accede a lo que el usuario puede ver. Los controles existentes definen el límite.



Confianza por diseño
Seguridad, privacidad y cumplimiento heredados de Microsoft 365.



Señales integradas
Las decisiones combinan identidad, dispositivo, datos y amenazas.



Contexto mínimo necesario
Solo el contexto relevante se usa para generar respuestas.



Verificable
Cada eslabón requiere evidencia y pruebas reproducibles.



Mejora continua
Observabilidad y métricas para optimizar y reducir riesgo.

LEYENDA

- Dependencia crítica
- - - Recomendación / Condicionada
- Punto de control / Validación

Readiness verificable: gates, madurez y evidencia para el go/no-go

Decidir sobre pilotos y escalamiento de Microsoft 365 Copilot con base en controles efectivos, evidencia objetiva y resultados medibles, no en percepciones.

GATE	DOMINIO	OBJETIVO DEL GATE	P0 CONTROLES ESENCIALES (EJEMPLOS)	EVIDENCIA MÍNIMA REQUERIDA	MADUREZ ACTUAL
 G0	REQUISITOS Habilitadores y dependencias	Verificar licencias, cuentas y prerequisites técnicos	- E5 vigente - Microsoft Copilot licencias asignables - Apps en canal soportado	 Inventario de licencias Excel/Export M365 Captura de consola	NE No evaluado
 G1	IDENTIDAD Acceso y autenticación	Asegurar identidad resistente y acceso condicional efectivo	- MFA resistente para privilegio - Conditional Access con enforcement - Authentication strength	 Informe CA / Sign-in logs MFA / Auth strength Políticas y reportes	NE No evaluado
 G2	DISPOSITIVO Estado y cumplimiento	Garantizar dispositivos confiables y gestionados	- Intune compliance con reglas activas - Device risk de MDE integrado - Cifrado, Secure Boot, BitLocker	 Estado de compliance Machine risk Inventory export	NE No evaluado
 G3	DATOS Protección y gobernanza	Reducir sobreexposición y proteger datos sensibles	- Purview labels y DLP activas - DAG / RCD en sitios sensibles - Retención y eDiscovery aplicables	 Reportes DAG / DLP Policy matches Audit / Retention status	NE No evaluado
 G4	AMENAZAS Detección y respuesta	Detectar, responder y contener amenazas a tiempo	- MDI, MDE, MDO, MDCA integrados - Alertas XDR y playbooks activos - Protección de correo y apps	 Alertas / Incidentes XDR Cobertura de apps Políticas y pruebas	NE No evaluado
 G5	MEDICIÓN Uso, outcomes y valor	Medir adopción, impacto y retorno esperado	- Telemetría habilitada (Usage/Dashboard) - Outcomes definidos y baselines - Finanzas informada y aprobada	 Usage report Outcomes baselines Modelo financiero	NE No evaluado

SERIE DE 2 VOLÚMENES

Volumen 1: Marco de licenciamiento y análisis comparativo por escenario (dimensión de decisión)



ESCALA DE MADUREZ



NE = No evaluado. No equivale ni a cumplimiento ni a incumplimiento.

SCORE DE READINESS (100 PUNTOS)



$$\text{Score} = \sum (\text{Peso} \times \text{Nivel de madurez [0-4]}) \times 25$$

CRITERIOS DE DECISIÓN PROPUESTOS



PILOTO APROBADO

- ✓ Todos los gates aprobados (≥ Nivel 3)
- ✓ Ningún P0 por debajo de Nivel 3
- ✓ Score de readiness ≥ 75 / 100
- ✓ Excepciones documentadas y aprobadas
- ✓ Plan de soporte y comunicación activo



ESCALA APROBADA

- ✓ Score de readiness ≥ 85 / 100
- ✓ Ningún P1 por debajo de Nivel 3
- ✓ Operación estable por ≥ 2 ciclos
- ✓ Outcomes en tendencia positiva
- ✓ Finanzas validó captura y ROI esperado

PATRONES DE BRECHA / EXCEPCIÓN



P0 por debajo de Nivel 3

Riesgo alto. Bloquea piloto o escala.



P1 por debajo de Nivel 3

Riesgo medio. Requiere plan de remediación con fecha y dueño.



NE en controles clave

Información insuficiente. Completar evaluación y evidencia.

PRINCIPIOS RECTORES



Decisiones basadas en evidencia.



Security, privacy y compliance por diseño.



Automatización con gobierno.



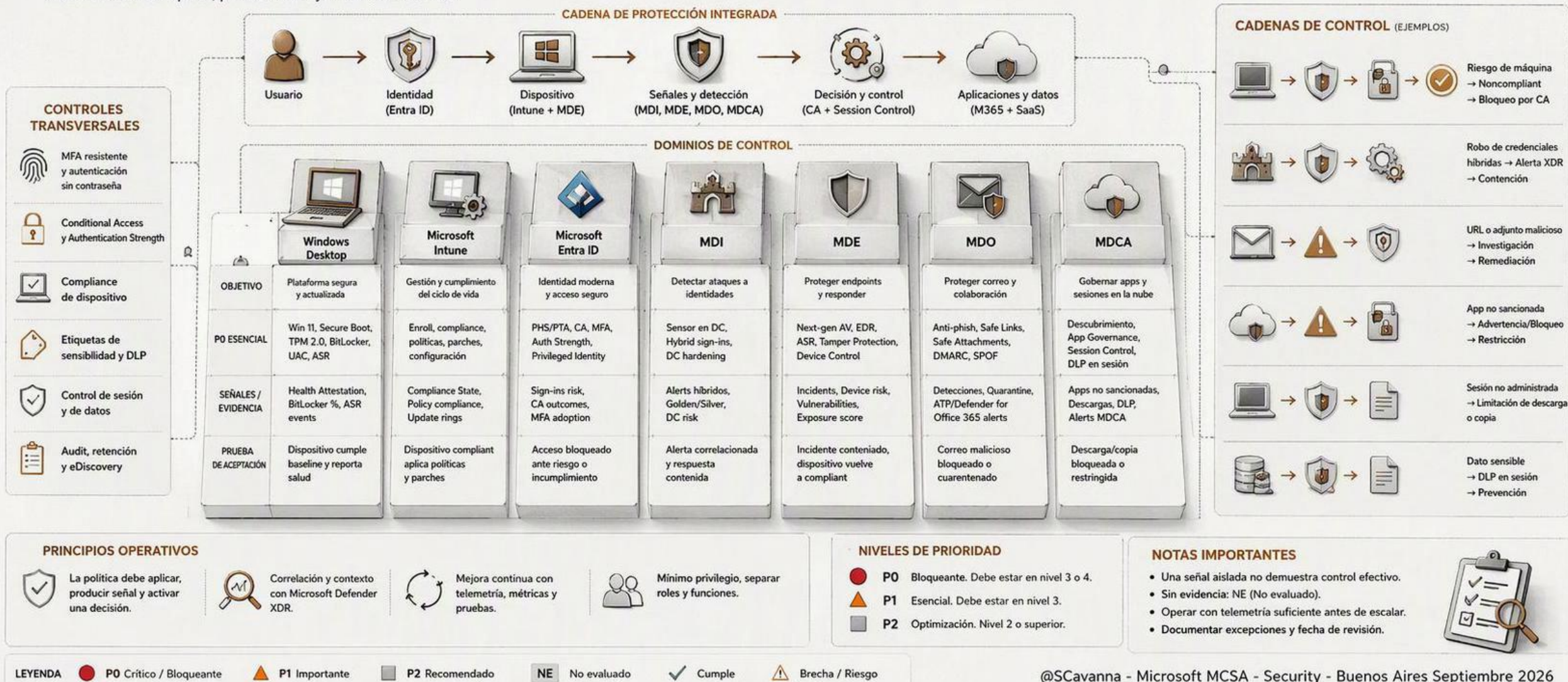
Mejora continua con métricas.



Plataforma, identidad y amenazas:

controles integrados para Microsoft 365 Copilot

La identidad y el dispositivo convierten señales de riesgo en decisiones de acceso y respuesta.
Cada control debe aplicar, producir señal y activar una decisión.



Datos y colaboración preparados paa Copilot: descubrir, contener, proteger y auditar

Copilot respeta los permisos existentes. La preparación consiste en identificar la sobreexposición, contener temporalmente, corregir el acceso, proteger el contenido y auditar de extremo a extremo.



CONTENCIÓN VS REMEDIACIÓN

CONTENER (medidas temporales)
RAC y RCD reducen riesgo inmediato mientras se corrige el acceso. No sustituyen la remediación.

REMIEDIAR (solución permanente)
Corregir permisos, propietarios, enlaces y governance. Revisión y recertificación periódica.

PUNTOS DE CONTROL TRANSVERSALES

Permisos mínimos y necesidad vigente para usuarios, grupos, buzones y sitios.

Sensibilidad y protección coherentes entre etiquetas, DLP y cifrado.

Visibilidad completa de exposición y actividad (DAG, DSPM, Audit).

Evidencia repetible y trazable para go/no-go y escala.

Propietarios y ciclos de atestación con soporte de excepciones.

DOMINIOS Y RESPONSABILIDADES CLAVE

ONE DRIVE

- Provisioning y acceso.
- Compartición y enlaces.
- Sincronización y dispositivos.
- Lifecycle al egreso.
- Etiquetas y DLP.

Repositorio personal de trabajo. Control de sharing y protección del contenido.

SHAREPOINT ONLINE

- Baseline de permisos y exposición (DAG).
- Propietarios y atestación periódica.
- Remediación de sobreexposición.
- RAC (control de acceso).
- RCD (control de descubrimiento).
- Lifecycle y archivo de sitios.
- Sharing seguro por defecto.

Repositorio colectivo principal. Permisos existentes determinan el contexto de Copilot.

EXCHANGE ONLINE

- Buzón principal en Exchange Online (requisito).
- Auditoría de buzones.
- Retención, holds y eDiscovery.
- Permisos y delegaciones (FullAccess, SendAs).
- Conectores, flujo y forwarding.

Fuente de grounding: correo, calendario y metadatos. Auditoría y retención obligatorias.

MICROSOFT PURVIEW

- Clasificación y etiquetas.
- DLP para M365, endpoint y Copilot.
- DSPM for AI: exposición y recomendaciones.
- Audit: interacciones Copilot.
- Retención de interacciones Copilot.
- eDiscovery e investigaciones.

Protección del contenido, auditoría, retención y gobierno integral.

LEYENDA DE ESTADO

P0 Crítico / Bloqueante

P1 Importante

P2 Recomendado

NE No evaluado

Cumple

Brecha / Riesgo

EVIDENCIA MÍNIMA (EJEMPLOS) *

- Export de reportes DAG y perm.
- Policy matches de DLP

- Casos de prueba con datos sintéticos
- Búsquedas de audit y eDiscovery

- Actas de atestación y excepciones
- Desempeño de DSPM

PRINCIPIO

Copilot solo opera sobre lo que el usuario ya puede ver. Menos sobreexposición, mejor valor y menor riesgo.

De assessment a escala:

roadmap y pruebas de aceptación en 180 días

El despliegue avanza por evidencia y criterios de salida. No escalar por fecha ni por cantidad de licencias compradas.



REGLA DE ESCALAMIENTO

Ampliar únicamente cuando los gates, los controles P0, la telemetría, el soporte, la privacidad y los outcomes cumplan sus criterios de salida.

1 0-30 DÍAS DESCUBRIR



- Confirmar licencias, topología y población.
- Exportar readiness y uso (baseline pre-piloto).
- Inventarios: identidad, dispositivos, datos y apps.
- Identificar riesgos P0 y dependencias críticas.
- Definir casos de uso, baseline y owners.

Criterio de salida

Inventarios completos, baseline capturada, backlog P0 priorizado y go/no-go inicial.

2 31-60 DÍAS CONTENER



- Fortalecer identidad: MFA resistente, CA, PIM.
- Dispositivos: Intune, MDE, compliance y riesgo.
- MDI health y postura de identidad híbrida.
- MDO: presets, Safe Links, Safe Attachments.
- Datos: DAG/DSPM, permisos, owners.
- Contención dirigida: RAC / RCD, DLP y auditoría.

Criterio de salida

Gates G1-G4 aprobados, P0 críticos cerrados o contenidos con plan y excepción vigente.

3 61-90 DÍAS PILOTAR



- Asignar licencias Copilot a cohorte elegible.
- Ejecutar test pack end-to-end con datos sintéticos.
- Soporte, comunicaciones y entrenamiento.
- Medir adopción (uso, tasa de activos, por app).
- Medir outcomes y experiencia del usuario.
- Revisar privacidad, IR, eDiscovery y rollback.

Criterio de salida

Todos los gates G0-G5 aprobados, outcomes positivos y sin brechas P0 nuevas.

4 91-120 DÍAS ESCALAR



- Escalar por anillos (canary → piloto → prod).
- Access reviews y recertificación periódica.
- DLP en enforcement. Remediación continua.
- Automatización y vinculación a XDR.
- Optimizar licencias según uso y outcome.

Criterio de salida

Operación estable, SLOs cumplidos y valor sostenido en cohortes ampliadas.

5 121-180 DÍAS OPTIMIZAR



- QBR: riesgo, adopción, outcomes y costos.
- TCO real y beneficios capturados.
- Retirar excepciones y reducir deuda.
- Nuevas capacidades y segunda ola de casos.
- Plan 6-12 meses y mejora continua.

Criterio de salida

ROI defendible, excepciones retiradas y siguiente ola aprobada.

ESCENARIOS INTEGRADOS DE PRUEBA (Debe ejecutarse en piloto)

1 Usuario sin prerequisites
Diagnóstico identifica causa; no se declara listo.

2 Administrador con método débil
No activa rol ni entra; evento auditable.

3 Dispositivo de alto riesgo
Acceso bloqueado; remediación restablece.

4 Robo de identidad híbrida
Alerta correlacionada, owner y contención dentro del SLO.

5 Archivo sobreexpuesto
Contenido contenido, permisos corregidos y no descubrible.

6 Dato sensible en IA no aprobada
Warn/block y evento; bypass solo por excepción.

7 URL maliciosa en correo
URL bloqueada y cadena investigable.

8 Acceso desde equipo no administrado
Sesión restringida; sin descarga/copia de dato alto.

9 Investigación de interacción
Prompt/respuesta de prueba recuperable según policy.

10 Egreso de empleado
Acceso revocado, datos transferidos/preservados y evidencia completa.

CADENCIAS MÍNIMAS DE REVISIÓN

- Diaria**
Incidentes críticos, health de sensores/conectores, acciones fallidas y cuentas de emergencia.
- Semanal**
Policy health, riesgo alto, phishing, DLP crítico, apps IA nuevas y soporte del piloto.
- Mensual**
Score por dominio, excepciones, exposición, OAuth, licencias, adopción y outcomes.
- Trimestral**
Pruebas de emergencia, access reviews, baseline, tabletop y QBR de valor.
- Anual o cambio material**
Arquitectura, taxonomía, retención, privacidad, threat model y business case.

GESTIÓN DE EXCEPCIONES

-  Justificación, riesgo y compensación
 -  Owner técnico y de negocio
 -  Inicio, vencimiento y plan de salida
 -  Evidencia y prueba asociada
 -  Aprobador y revisión periódica
 -  Incidentes relacionados
- Una excepción sin fecha de expiración es deuda no gobernada.

LEYENDA

- P0 Crítico / Bloqueante
- ▲ P1 Importante
- P2 Recomendado
- NE No evaluado
-  Cumple
-  Brecha / Riesgo

 Las pruebas usan datos sintéticos y timestamps correlacionables. Conservar evidencia en repositorios controlados.

Estado actual del tenant: No evaluado.

Del uso al valor:

medición, TCO, ROI y optimización de licencias

Actividad no equivale a valor. Vincule el uso con outcomes verificables, costos reales y captura financiera para decidir ampliar, rediseñar, reasignar o retirar.

SERIE DE 2 VOLÚMENES
Volumen 1: Marco de licenciamiento y análisis comparativo por escenario (dimensión de decisión)



i La medición requiere línea base previa al piloto, cohortes comparables y evidencia trazable.



FUENTES DE MEDICIÓN

Readiness report Elegibilidad técnica, licencias, canal de actualización y actividad. Ventana: 28 días	Usage report Habilitados, usuarios activos, tasa de activos y adopción por app. Ventana: 28 días	Copilot Dashboard Readiness, adopción, impacto y sentimiento. Ventanas y latencias específicas por informe.	Sistemas de negocio CRM, ITSM, ERP, calidad, ciclo, satisfacción, cumplimiento. Línea base 4-8 semanas	Costos y soporte Licencias, servicios, remediación, operación, soporte y change. Conciliación con Finance
--	--	---	--	---

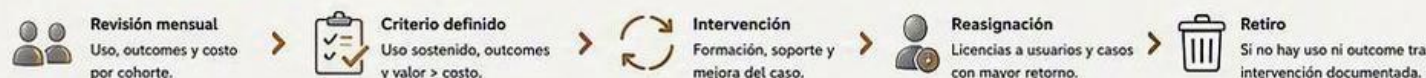
TABLERO EJECUTIVO MÍNIMO

	ESTADO
¿Estamos listos técnicamente? Gates, PO/P1, score, evidencia vencida.	
¿Se usa? Tasa de activos y adopción por app/caso.	
¿Funciona sin fricción? Experiencia, latencia, tickets, FP.	
¿Es seguro y gobernado? Incidentes, acceso excesivo, DLP, OAuth, MTTR.	
¿Produce resultado? Outcomes, calidad, ciclo y satisfacción.	
¿Conviene económicamente? TCO, ROI, NPV, payback y sensibilidad.	

MODELO FINANCIERO

COMPONENTES DE BENEFICIO	COSTOS	MÉTRICAS DE DECISIÓN
Productividad capturada Horas verificadas x costo hora x tasa de captura. Calidad / retrabajo evitado Reducción de error o retrabajo x costo unitario. Velocidad / capacidad Throughput o reducción de ciclo x valor por unidad. Crecimiento Oportunidades x conversión atribuible x margen. Riesgo (no ahorro realizado) (Probabilidad x impacto) antes - después.	TCO INCREMENTAL • Licencia Copilot (costo incremental). • Remediación incremental. • Despliegue, change y formación. • Soporte y operación incremental. • Medición y sistemas de reportes. • Contingencia. TCO COMPLETO • TCO incremental. • Porción atribuible de ES. • Operación de controles. • Costos comunes.	ROI (Beneficios ajustados - TCO) / TCO NPV Valor presente neto (tasa aprobada). Payback Meses para recuperar la inversión. Escenarios Bajo / Base / Alto.

OPTIMIZACIÓN Y REASIGNACIÓN DE LICENCIAS



PRINCIPIOS DE MEDICIÓN Y VALOR



LEYENDA ● P0 Crítico / Bloqueante ▲ P1 Importante ■ P2 Recomendado ■ NE No evaluado ✓ Cumple ⚠ Brecha / Riesgo

i Ventanas y latencias según reporte. Calibrar por criticidad, regulación y geografía.

Estado actual del tenant: No evaluado (NE).

01 | EL SISTEMA OPERATIVO DE GOBIERNO DE MICROSOFT 365 COPILOT Y AGENTES

SERIE INFOGRÁFICAS
Gobierno de Microsoft 365 Copilot y Agentes
01 de 07



Tres pilares, nueve planos de control y cien controles operativos

SUPERFICIES CUBIERTAS

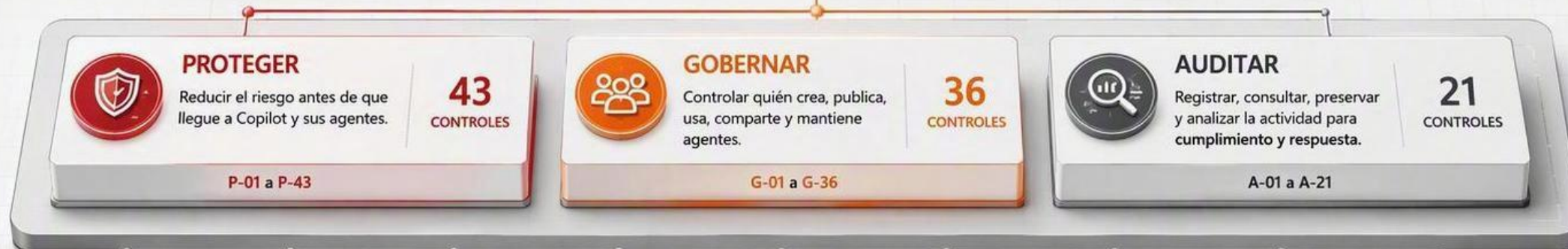
Sujetos, fuentes y vectores gestionados por los controles



*Disponible según escenario de licenciamiento.

TRES PILARES DE GOBIERNO

Cien controles organizados en tres funciones complementarias.



NUEVE PLANOS DE CONTROL

Consolas y servicios que implementan y orquestan los controles.



Cada plano tiene un ámbito funcional específico.

TRES ESCENARIOS DE CAPACIDAD

La cobertura y las capacidades cambian según la licencia habilitante.



LEYENDA DE ESTADO: Incluido / Disponible Parcial / Condicionado (Preview) NV No verificado No incluido Consumo variable / PAYG

Los 100 controles (P-01 a P-43, G-01 a G-36, A-01 a A-21) se implementan a través de estos planos y varían según el escenario de licenciamiento.



DÓNDE SE DETIENE EL RIESGO ANTES DE LLEGAR A COPILOT

Controles preventivos distribuidos en dominios críticos que reducen el riesgo antes del uso de Copilot, agentes y conectores.

1 IDENTIDAD Y ACCESO



-  **P-01** Conditional Access sobre Office 365
-  **P-02** Riesgo de usuario y sesión
-  **P-03** Privileged Identity Management (PIM)
-  **P-04** Microsoft Entra Agent ID
-  **P-05** Permisos de conectores
-  **P-06** Consentimiento de aplicaciones y OAuth

2 DISPOSITIVOS



-  **P-07** App Protection Policies (MAM)
-  **P-08** Cumplimiento del dispositivo
-  **P-09** Integración Intune – Defender
-  **P-10** Configuración de Microsoft Edge*
-  **P-11** Configuración de Windows*

* Control pendiente de verificación

3 AMENAZAS Y SHADOW AI



-  **P-12** Microsoft Defender XDR
-  **P-13** Microsoft Defender for Cloud Apps
-  **P-14** Aplicaciones de IA generativa
-  **P-15** Aplicaciones OAuth
-  **P-16** XPIADetected
-  **P-17** JailbreakDetected

4 PROTECCIÓN DE DATOS



-  **P-18** Sensitivity Labels
-  **P-19** Cifrado y derecho EXTRACT
-  **P-20** DLP de Prompts
-  **P-21** Web Search en Copilot
-  **P-22** Políticas de retención

5 OVERSHARING EN SHAREPOINT



-  **P-37** Diagnóstico de Acceso Excesivo (DAG)
-  **P-38** Restricción de Compartición (RCD)
-  **P-39** Site Access Reviews + RAC
-  **P-40** Retirada de restricciones (RCD)

SECUENCIA OPERATIVA DOCUMENTADA



OBJETIVO

Reducir la superficie de ataque y la exposición de datos antes de que el riesgo pueda materializarse en Copilot, agentes y conectores.

ENFOQUE PREVENTIVO

-  Menos privilegio
-  Condiciones de acceso adaptativas
-  Dispositivos seguros y gestionados
-  Datos clasificados y controlados
-  Fuentes de datos corregidas

ALCANCE

-  Microsoft Copilot
-  Copilot Chat
-  Agentes y conectores
-  Fuentes de datos en Microsoft 365

CÓMO SE REDUCE EL RIESGO



LEYENDA DE ESTADO

-  Incluido / Disponible
-  Parcial / Condicionado (Preview)
-  NV No verificado
-  No incluido
-  Consumo variable / PAYG

Los controles P-01 a P-40 forman parte del pilar PROTEGER. Ver detalle completo en la matriz de escenarios (P-01 a P-43).

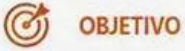
NOTAS

Algunos controles están en Preview, Próximamente o pendientes de verificación (NV). No deben considerarse como capacidades firmes hasta su disponibilidad GA.

GOBERNAR: DEL MAKER AL AGENTE PUBLICADO



Controles para crear, configurar, compartir, usar y mantener agentes de forma segura y conforme.



OBJETIVO
Asegurar que los agentes se creen y operen bajo políticas corporativas de acceso, seguridad, datos y ciclo de vida.



- ALCANCE**
- Agent Builder
 - Copilot Studio
 - Conectores y fuentes de conocimiento
 - Entornos y canales
 - Publicación y uso
 - Retiro y mantenimiento

CICLO DE VIDA DEL AGENTE



1 MICROSOFT 365 ADMIN CENTER

Gobernar qué agentes existen y quién puede usarlos.

- G-01 Allowed agent types
- G-02 Sharing (compartir y acceso)
- G-03 User access (quién puede usar)
- G-04 Agent Registry (registro y catálogo)
- G-05 Aprobación, bloqueo y reasignación
- G-06 Agent management rules
- G-07 Security templates
- G-08 Frontier y self-service purchases

2 POWER PLATFORM ADMIN CENTER

Controlar entornos, conectores, canales, capacidad y consumo.

- G-09 Data policies (segmentación de datos)
- G-10 Autenticación obligatoria
- G-11 Conectores y MCP
- G-12 Endpoint filtering (allow/block list)
- G-13 Canales y métodos de publicación
- G-14 Triggers (disparadores)
- G-15 Alcance por entorno
- G-16 Copilot hub (gobernanza)
- G-17 Límites de consumo y capacidad

3 COPILOT STUDIO (POR AGENTE)

Configurar cada agente con controles de seguridad y operación.

- G-18 Authenticate with Microsoft
- G-19 End user credentials (credenciales del usuario final)
- G-20 Moderation level (nivel de moderación)
- G-21 Fuentes de conocimiento (datos y configuración)
- G-22 Seguridad del canal
- G-23 Automatic security scan
- G-24 Real-time risk assessment y runtime protection status

AGENT BUILDER vs COPILOT STUDIO

AGENT BUILDER

- ✓ Gobierno de acceso, compartición, tipo y bloqueo.
- ✗ Sin control granular verificado de fuentes de conocimiento.

COPILOT STUDIO

- ✓ Data policies, conectores, canales y triggers.
- ✓ Autenticación y credenciales.
- ✓ Controles de seguridad por agente.

PRINCIPIOS TRANSVERSALES

- Principio de mínimo privilegio
- Privacidad y protección de datos
- Trazabilidad y auditoría
- Ciclo de vida: crear, usar, revisar, retirar

La gobernanza aplica a agentes de Agent Builder y Copilot Studio, sus conectores, datos y herramientas.

LEYENDA DE ÍCONOS

- ✓ Permitido
- ⚠ Condicionado / Requiere configuración
- 🔄 Preview / Próximamente
- ⚪ No verificado
- ✗ No permitido
- 💰 Consumo variable / PAYG

Los controles G-01 a G-36 forman parte del pilar GOBERNAR. Ver detalle completo en la matriz de escenarios (G-01 a G-36).

04 AUDITAR: DE LA INTERACCIÓN A LA EVIDENCIA FORENSE

Registros, consulta, preservación y análisis para investigación, cumplimiento y respuesta.

1 REGISTRO BASE

Eventos y telemetría de Copilot y agentes



- CopilotInteraction
- Eventos de Copilot Studio
- AgentId, AgentName y AgentVersion
- AccessedResources
- XPIADetected
- JailbreakDetected
- Retención: 90 días (estándar)*

2 CONSULTA Y EXTRACCIÓN

Acceso a registros y exportación



- Purview Audit (búsqueda avanzada)
- Search-UnifiedAuditLog (PowerShell)
- Audit Search (Graph API)
- Exportación a CSV
- Office 365 Management Activity API

3 CONTENIDO Y CONSERVACIÓN

Preservar para cumplimiento e investigación



- eDiscovery Standard
- Legal Hold
- Exportación de prompts y respuestas
- Retention Policies
- Preservación de evidencias

4 LECTURA DE INTERACCIONES

Visibilidad de contenido y riesgos de datos



- DSPM Activity Explorer
- Prompts, respuestas y web queries
- Detección de Sensitive Information Types (SIT)
- Alertas y detecciones de riesgo

5 OBSERVABILIDAD DEL AGENTE

Uso, rendimiento y diagnóstico operativo



- Copilot Studio Monitor
- Transcripciones en Dataverse
- PPAC Copilot hub
- Agents usage report (Preview)**
- Viva Insights

6 CAPAS SUPERIORES

Análisis avanzado, correlación e integración



- Audit Premium***
- eDiscovery Premium***
- Microsoft Sentinel (SIEM)
- Application Insights
- Observabilidad de Agent 365***
- Integración con XDR y otras fuentes

PROPÓSITO

Convertir cada interacción de Copilot y agentes en evidencia confiable, consultable y preservada para actuar con rigor.

BENEFICIOS

- ✓ Cumplimiento y auditoría
- 🔍 Investigación y respuesta
- 🔒 Preservación legal y retención
- 📈 Visibilidad operativa y de adopción

FLUJO DE EVIDENCIA



CORRELACIÓN RECOMENDADA



NOTAS

- * 90 días de retención estándar.
- ** Disponibilidad en Preview, sujeta a cambios.
- *** Requiere licenciamiento adicional (Audit Premium, eDiscovery Premium, Agent 365 o E7).
- Algunas capacidades requieren consumo variable (PAYG).

MUCHAS CONSOLAS, UNA POLÍTICA: MAPA OPERATIVO DE CONTROLES

Cada consola implementa controles en un ámbito específico. Ninguna sustituye al conjunto.



FUNCIONES DE CONTROL	 MAC Microsoft 365 admin center	 PPAC Power Platform admin center	 DEF Microsoft Defender	 ENTRA Microsoft Entra ID y Agent ID	 INTUNE Microsoft Intune	 PURVIEW Microsoft Purview	 SPO SharePoint Online	 CS Copilot Studio	 A365 Agent 365*
 IDENTIDAD Y ACCESO	 Habilitar Aprobar Bloquear	 Restringir datos y conectores Autenticación	 Detectar apps y comportamiento Análisis OAuth	 Autenticar Condicionar Gobernar ID	 Cumplimiento de dispositivo Acceso condicional	 Clasificar Proteger DLP	 Permisos Accesos Externos	 Seguridad del canal Autenticación Credenciales	 Agent ID Políticas unificadas SSO de agentes
 DISPOSITIVOS	 Políticas de acceso por dispositivo	 Acceso por entorno Canales	 Postura y riesgo Endpoint MDATP	 Riesgo del dispositivo Autenticación	 Configurar Cumplir Proteger apps	 Protección en dispositivo Etiquetado	 Acceso desde dispositivos Bloqueos	 Apps y plugins seguro en canal Configuración	 Postura de agentes Telemetría de dispositivos
 AMENAZAS Y SHADOW AI	 Bloquear apps no aprobadas Frontier	 Restringir conectores y MCP	 Descubrir Detectar Responder	 Condición por riesgo Políticas	 Integración con Defender Baselines	 DLP de prompts SIT Web Search	 Compartición externa Controles	 Moderación Evaluación de riesgos en tiempo real	 Detección avanzada Protección runtime Alertas
 DATOS Y CUMPLIMIENTO	 Etiquetas y retención Políticas	 Data policies Segmentación Alcance	 Protección de datos en reposo y en tránsito	 Clasificación accesos Sensibilidad	 Cifrado Protección de datos	 Clasificar Prevenir Auditar Conservar	 Retención Etiquetas Permisos	 Fuentes de Conocimiento Conectores seguros	 Gobierno de datos Contexto unificado Cumplimiento
 OVERSHARING (SHAREPOINT)	 Políticas globales de acceso externo	N/A	 Monitoreo de compartición anómala	 Grupos y asignaciones condicionales	 Acceso a datos desde dispositivos administrados	 DAG / RCD Accesos y revisiones Bloqueos	 DAG / RCD Site Access Reviews RAC / Block download	N/A	 Visibilidad unificada Riesgo de exposición de sitios
 INVENTARIO Y CICLO DE VIDA	 Catálogo de agentes Aprobación	 Inventario de soluciones Entornos	 Riesgos de apps y conectores Alertas	 Ciclo de vida de identidades (humanas y de agente)	 Onboarding Compliance Offboarding	 Retención eDiscovery Conservación	 Propiedad Sitios Ficheros	 Versionado Publicación Despublicación	 Registro central Estados de agentes Retiro y re-asignación
 CONFIGURACIÓN DEL AGENTE	 Allowed agent types Bloqueo	 Canales Conectores Triggers	 Evaluación de apps y plugins Jailbreak / XPIA	 Permisos del agente (Agent ID) Consentimiento	 Protección de plugins y apps empresariales	 Fuentes Conectores Políticas de datos	 Acceso a contenidos del sitio	 Moderación Conectores Fuentes	 Políticas unificadas Configuración central Runtime protection
 AUDITORÍA Y OBSERVABILIDAD	 Audit Standard Búsquedas Exportaciones	 Copilot hub Limites y uso Reportes	 Alertas Incidentes Investigación	 Sign-ins Logs de identidad Riesgo	 Cumplimiento Eventos Inventario	 Audit Premium DSPM eDiscovery	 Logs de acceso Cambios Retención	 Copilot Studio Monitor Transcripciones Eventos	 Observabilidad integrada Conexión SIEM

LEYENDA DE ÍCONOS

Configurar / Habilitar

Proteger / Restringir

Detectar / Monitorear

Permitir / Autenticar

Gobernar / Administrar

Gestionar Datos

Auditar / Reportar

NOTAS
El alcance de cada control depende de la licencia y del escenario (E1, E2 o E3). Ver detalle en la infografía 06.

REFERENCIA DE CONTROLES
Consulte los checklists A.1-A.8 para la lista completa de controles (P-01 a A-21).

* Agent 365 disponible en escenarios con Microsoft 365 E7.
** Algunas capacidades requieren consumo variable (PAYG).

06

QUÉ HABILITA CADA ESCENARIO: E1, E2 Y E3

Cobertura acumulativa por capacidad, licencia habilitante y estado de disponibilidad.

CAPACIDADES ¿QUÉ SE HABILITA?	CONTROLES PREVENTIVOS Y AUDITORÍA ESTÁNDAR Base de protección y visibilidad	GOBIERNO AVANZADO DE DATOS Y CUMPLIMIENTO Actuar sobre datos y comportamiento	CONTROL DE IDENTIDADES Y SEGURIDAD DE AGENTES Gobernar al agente como sujeto operativo	LICENCIA HABILITANTE	ESTADO
1. IDENTIDAD HUMANA Acceso, riesgo, PIM, permisos y consentimiento	Incluido Conditional Access, riesgo, PIM básico	Incluido Todo E1 + governance identity más granular	Incluido Todo E2 + políticas unificadas de identidad	E1 / E3 / E5	GA
2. IDENTIDAD DE AGENTE Agent ID, políticas unificadas, SSO de agentes	Limitado Agent ID básico (sin políticas unificadas)	Ampliado Más controles sobre identidades de agente	Completo Identidades de agente plenamente gobernadas	E7 / Agent 365**	Parcial
3. ENDPOINT Cumplimiento, configuración y protección de dispositivos	Incluido Intune + Defender para Endpoint	Incluido Todo E1	Incluido Todo E2	E1 / E3 / E5	GA
4. AMENAZAS Y SHADOW AI XDR, IA generativa, OAuth apps, detección de jailbreak	Incluido Defender XDR, Office 365 ATP, apps de IA generativa	Ampliado Detección y respuesta más avanzada	Completo Protección y respuesta de próxima generación	Microsoft 365 E3 / E5	GA
5. PROTECCIÓN DE DATOS Etiquetas, cifrado/EXTRACT, DLP de prompts, retención	Parcial Etiquetas y DLP básico, retención estándar	Ampliado DSPM, DLP avanzado, eDiscovery Premium, clasificación avanzada	Completo DSPM avanzado, clasificación ML, AI en cumplimiento	Purview Suite (E2+) E7 / Agent 365	Parcial
6. OVERSHARING DAG, RCD, Site Access Reviews, RAC, Block Download	Incluido DAG, RCD, Site Access Reviews, RAC	Ampliado Controles de oversharing con automatización	Completo Automatización y remediación continua	E1 / E3 / E5	GA
7. CICLO DE VIDA DEL AGENTE Inventario, tipos, registro, aprobación, retiro y bloqueo	Parcial Tipos permitidos, registro y bloqueo básico	Ampliado Agent management rules, templates, aprobaciones avanzadas	Completo Ciclo de vida completo, telemetría de dispositivos de agentes	E5 / Purview Suite Agent 365**	Parcial
8. AUDIT Y eDISCOVERY Audit Standard, eDiscovery Standard, legal hold, exportación	Incluido Audit Standard, eDiscovery Standard	Ampliado eDiscovery Premium, retenciones avanzadas, conservación legal	Completo Conservación avanzada, auditoría completa de interacciones	Purview Suite (E2+) E7 / Agent 365	Parcial
9. OBSERVABILIDAD AVANZADA Copilot Studio Monitor, transcripciones, usage report, PPAC hub	Parcial Copilot Studio Monitor (limitado), PPAC Copilot hub	Ampliado Agents usage report (Preview), transcripciones en Dataverse	Completo Observabilidad integral de agentes (trazas, telemetría, experiencias)	Purview Suite (E2+) Agent 365	Preview
10. INTEGRACIÓN CON SIEM Exportación de logs, Sentinel, correlación	Parcial Exportación al SIEM (conector estándar)	Ampliado Conectores avanzados, Sentinel nativo*	Completo Integración nativa con Sentinel y otras fuentes	E3 / E5 Microsoft Sentinel	Parcial
11. PAYG Y CAPACIDADES EXTERNAS Consumo variable y servicios externos	Disponible (PAYG) Algunas capacidades con consumo variable	Más opciones (PAYG) DSPM, premium add-ons, conectores externos	Completo Agent 365 incluye capacidades avanzadas **, más PAYG	Varía por servicio (PAYG)	PAYG

LEYENDA DE ESTADO

Incluido (GA) Parcial / Condicionado Próximamente / Preview No verificado No incluido Consumo variable / PAYG

NOTAS

Los escenarios son acumulativos: E2 incluye todo lo de E1; E3 incluye todo lo de E2.

REFERENCIA DE CONTROLES

Consulte la matriz completa P-01 a P-43, G-01 a G-36, A-01 a A-21 para detalle por control y escenario.

* Requiere licenciamiento de Sentinel.

** Agent 365 disponible en escenarios con Microsoft 365 E7.

DE LA EVALUACIÓN A LA OPERACIÓN: HOJA DE RUTA, BRECHAS Y CAPACIDADES EN PREVIEW

Priorice controles disponibles, gestione brechas y planifique capacidades en Preview y no verificadas.

HOJA DE RUTA OPERATIVA

0 – 30 DÍAS

- DAG y RCD en sitios de alto riesgo.
- DLP de prompts y web search según SIT.
- Decisión sobre web search.
- Configuración de Agents > Settings.
- Data policy de PPAC para autenticación, canales, HTTP, Skills y conectores.

30 – 90 DÍAS

- Retention policies.
- PIM y Conditional Access.
- Agent management rules y security templates.
- Exportación del unified audit log al SIEM.
- Política corporativa de defaults seguros de Copilot Studio.



OBJETIVO

Implementar controles críticos disponibles y sentar las bases para gobierno, cumplimiento y auditoría continua.

PRINCIPIO

Ejecute primero lo disponible y verificable; mantenga Preview y NV fuera de compromisos de cumplimiento.

BRECHAS E INCERTIDUMBRES (NO VERIFICADO)

- NV Hunting específico de interacciones de Copilot en Defender XDR.
- NV Restricción granular de fuentes para Agent Builder.
- NV Dependencia de environment routing respecto de Managed Environments.
- NV Disponibilidad exacta de ciertos configuration profiles de Intune.
- NV Alcance de Customer Lockbox en E1.

CAPACIDADES EN PREVIEW

- P Security Dashboard for AI
- P Controles de IA en model-driven apps
- P Agents usage report
- P Customer comments summary
- P Bloqueo de SIT en prompts
- P Frontier
- P Exclusión de correo externo
- P Coexistencia DSPM actual y classic

DECISIONES DE INVERSIÓN

PURVIEW SUITE
Gobierno avanzado de datos, DLP, eDiscovery Premium y retención avanzada.

AGENT 365 O MICROSOFT 365 E7
Control de identidades de agente, seguridad avanzada y observabilidad unificada.

SENTINEL
Integración nativa con Microsoft 365 y Copilot; opción recomendada cuando no exista un SIEM apropiado.

GOBERNANZA CONTINUA

- Revisar postura
- Actualizar controles
- Monitorear y detectar
- Investigar evidencias
- Adaptar políticas

ESTADO DE REFERENCIA

- GA Disponible (General Availability)
- P Preview / Próximamente
- NV No verificado
- No incluido / No aplica
- Parcial / Condicionado
- Consumo variable / PAYG



Revise la matriz completa P-01 a P-43, G-01 a G-36, A-01 a A-21 para detalle por control y escenario.

NOTAS

- Los escenarios son acumulativos: E2 incluye todo lo de E1; E3 incluye todo lo de E2.

\$ Algunas capacidades requieren consumo variable (PAYG).

LEYENDA DE ICONOS

- Identidad
- Datos
- Seguridad
- Dispositivo
- Auditoría
- Governance

COBERTURA POR ESCENARIO (ACUMULATIVA)

- E1** Controles preventivos y auditoría estándar
- E2** Gobierno avanzado de datos y cumplimiento
- E3** Control de identidades y seguridad de agentes

